

MAINCRAFTS TECHNOLOGY

Cybersecurity & Ethical Hacking

Internship Program

TASK-1

Cybersecurity Threat Intelligence Report

(2024-2025)

Awareness & Research Project

Prepared by: –

Dev Vaghela

B.E Information Technology | Gujarat Technological University

Cybersecurity Analyst Intern (Simulation)

4 July 2026

Table of Contents

1. Introduction to Cybersecurity	3
2. Major Modern Cyber Threats (2024–2025).....	4
2.1 AI-Powered Phishing & Deepfake Attacks.....	4
2.2 Ransomware-as-a-Service (RaaS).....	4
2.3 Cloud Security Misconfigurations	5
2.4 IoT Vulnerabilities	6
2.5 Zero-Day Exploits.....	6
3. Conclusion & Future Scope	8
4. References.....	9

1. Introduction to Cybersecurity

1.1 What is Cybersecurity?

Cybersecurity is the discipline of protecting networks, systems, devices, and data from unauthorized access, disruption, or theft. It combines technical controls (firewalls, encryption, access management), organizational processes (policies, incident response), and human awareness (training, secure behaviour) to reduce the risk of digital compromise. As businesses and individuals increasingly rely on cloud services, mobile devices, and interconnected systems, cybersecurity has moved from being a purely technical concern to a core business and personal risk-management function.

1.2 Why is it Important for Individuals and Businesses?

For individuals, weak cybersecurity practices can lead to identity theft, financial fraud, and loss of personal data. For businesses, the stakes are larger: a single breach can result in regulatory fines, lawsuits, operational downtime, loss of customer trust, and in severe cases, an inability to continue operating. Critical sectors such as healthcare, finance, and energy are especially sensitive because a successful attack can disrupt essential services and put lives at risk, not just revenue.

1.3 Current Relevance

The threat landscape has intensified sharply in the 2024–2025 period. Ransomware groups now operate as commercial "as-a-service" businesses, artificial intelligence has made phishing and impersonation dramatically more convincing, and the number of connected IoT devices has grown into the tens of billions, expanding the attack surface faster than most organizations can secure it. At the same time, digital dependency continues to rise: nearly every business function, from payments to healthcare records, now runs on interconnected software, making resilience to cyberattacks a matter of organizational survival rather than a purely IT concern.

2. Major Modern Cyber Threats (2024–2025)

2.1 AI-Powered Phishing Attacks

AI-powered phishing uses generative AI and deepfake technology to craft highly convincing emails, voice calls, and video calls that impersonate trusted individuals such as executives or colleagues. Unlike traditional phishing, which often contains spelling errors or generic language, AI-generated lures are personalized, grammatically flawless, and can include synthetic voice or video that is difficult to distinguish from a real person.

Impact

- Individuals: victims can be tricked into revealing credentials, transferring money, or sharing personal data through convincing voice or video impersonation of someone they trust.
- Organizations: successful attacks can result in direct financial loss, unauthorized wire transfers, compromised executive accounts, and reputational damage once the incident becomes public.

Real-World Case Study

In February 2024, a finance employee at the UK-based engineering firm Arup was deceived into transferring approximately \$25 million after attackers staged a video conference call using AI-generated deepfakes of the company's CFO and other senior executives. Every face and voice on the call was synthetic, yet convincing enough that the employee proceeded with multiple transfers before the fraud was discovered. The case is widely cited as one of the first large-scale corporate losses caused by multimodal (audio and video) deepfake fraud.

Preventive Measures

- Verify high-value or unusual requests (fund transfers, credential resets) through a separate, pre-established communication channel rather than trusting the call or email alone.
- Deploy AI-aware email and communication security tools capable of flagging synthetic voice/video and anomalous sender behaviour.
- Run regular security awareness training that specifically covers deepfake and voice-cloning scenarios, not just traditional phishing red flags.

2.2 Ransomware-as-a-Service (RaaS)

Ransomware-as-a-Service is a criminal business model in which ransomware developers lease their malware, infrastructure, and negotiation support to affiliates in exchange for a share of the ransom. This has lowered the technical barrier to launching a ransomware attack, allowing less-skilled criminals to carry out sophisticated intrusions.

Impact

- Individuals: personal and medical data exposed in a breach can be used for identity theft or targeted fraud, especially when healthcare or financial providers are hit.
- Organizations: encrypted systems halt operations, exfiltrated data is used for double-extortion, and recovery costs, regulatory penalties, and reputational harm can run into the tens or hundreds of millions of dollars.

Real-World Case Study

In February 2024, the ALPHV/BlackCat RaaS group attacked Change Healthcare, a UnitedHealth Group subsidiary that processes a large share of US medical claims. Attackers encrypted key systems and exfiltrated roughly six terabytes of data, including Social Security numbers and medical records affecting an estimated 192.7 million individuals. UnitedHealth ultimately paid a \$22 million ransom, and total recovery and response costs were later estimated at close to \$3 billion, disrupting pharmacy and insurance operations across the United States for weeks.

Preventive Measures

- Maintain offline, regularly tested backups so encrypted systems can be restored without paying a ransom.
- Apply a Zero Trust security model and network segmentation to limit how far an attacker can move after an initial compromise.
- Patch internet-facing systems promptly and monitor for the credential-theft and lateral-movement techniques RaaS affiliates commonly use.

2.3 Cloud Security Misconfigurations

Cloud misconfigurations occur when storage, identity, or network settings in cloud environments (AWS, Azure, GCP) are left in an insecure state, most commonly a storage bucket or database left publicly accessible, hardcoded credentials, or over-permissioned access roles. Because cloud security operates on a shared-responsibility model, most of these failures originate on the customer side rather than the provider's infrastructure.

Impact

- Individuals: personal records stored in an exposed bucket (IDs, financial details, health data) can be indexed and harvested by automated scanners within hours of exposure.
- Organizations: exposed data leads to compliance violations (GDPR, HIPAA), loss of customer trust, and increasingly, direct ransom demands after attackers re-encrypt exposed cloud storage.

Real-World Case Study

In 2024, researchers discovered that Football Australia had left AWS access keys embedded in plain text within its website source code, granting access to 127 storage containers. One exposed bucket contained personal details of football players, along with attendee purchase data and internal source code; the exposure reportedly went undetected for over 700 days. Separately, in January 2025, a group calling itself Codefinger exploited stolen AWS credentials to re-encrypt victims' S3 buckets using AWS's own customer-provided encryption key feature (SSE-C), making the data unrecoverable without paying a ransom — effectively turning a routine credential leak into a full ransomware incident.

Preventive Measures

- Enable account- and bucket-level "block public access" settings by default, and never hardcode access keys in source code or repositories.
- Use automated cloud security posture management (CSPM) tools to continuously scan for open storage, excessive permissions, and disabled logging.
- Apply least-privilege IAM policies and rotate credentials regularly, especially for keys used in CI/CD pipelines.

2.4 IoT Vulnerabilities

Internet of Things (IoT) devices — routers, IP cameras, DVRs, smart TVs, and industrial sensors — are frequently shipped with weak default credentials, infrequent patching, and limited built-in security. With the global installed base of connected devices now well over 20 billion, these devices have become an attractive target for building large botnets.

Impact

- Individuals: compromised home routers or cameras can be used for surveillance, credential theft, or silently enrolled into a botnet without the owner's knowledge.
- Organizations: botnets built from hijacked IoT devices are used to launch massive Distributed Denial-of-Service (DDoS) attacks capable of taking down corporate networks and online services.

Real-World Case Study

The Aisuru botnet, which emerged in late 2024, compromised between 300,000 and 700,000 routers, DVRs, and IP cameras by scanning for weak credentials and known vulnerabilities, in the same way the original Mirai botnet operated in 2016. By October 2025, Aisuru-driven traffic forced Microsoft Azure to absorb a record 15.72 Tbps DDoS flood sourced from more than 500,000 IP addresses. Separately, the BadBox 2.0 campaign was found in 2025 to have compromised more than 10 million smart TVs and streaming devices through pre-installed malware baked into the supply chain before the devices ever reached consumers.

Preventive Measures

- Change default credentials on every IoT device immediately after setup, and disable remote administration where it isn't needed.
- Keep device firmware updated and isolate IoT devices on a separate network segment (VLAN) away from critical business systems.
- Vet the supply chain of connected devices before deployment to reduce the risk of pre-installed malware.

2.5 Zero-Day Exploits

A zero-day is a vulnerability that is exploited before the vendor is aware of it or has released a patch, leaving defenders with no prior signature or warning. In 2024 and 2025, attackers increasingly focused on enterprise "edge" devices — VPNs, firewalls, and file-transfer appliances — because they sit at the network perimeter, often lack endpoint monitoring, and provide a direct path into the internal network once compromised.

Impact

- Individuals: zero-days in widely used software (browsers, mobile OS) can lead to silent device compromise and data theft with no visible warning signs.
- Organizations: a single exploited zero-day in perimeter infrastructure can give an attacker unauthenticated remote access to the entire internal network, often undetected for months.

Real-World Case Study

In January 2025, Ivanti disclosed CVE-2025-0282, a critical buffer-overflow vulnerability in its Connect Secure VPN appliances, which Mandiant confirmed had already been exploited in the wild since mid-December 2024 by a suspected China-nexus espionage group. This followed an earlier pair of Ivanti zero-days (CVE-2023-46805 and CVE-2024-21887) exploited throughout 2024 by multiple state-linked actors, including an incident that affected systems belonging to the U.S. Cybersecurity and Infrastructure Security Agency (CISA) itself. Separately, the Cl0p ransomware group's 2023 exploitation of a SQL-injection zero-day in MOVEit Transfer eventually affected more than 2,500 organizations and tens of millions of

individuals, with evidence suggesting the group had quietly tested the flaw years before launching a mass campaign.

Preventive Measures

- Apply vendor patches and security advisories immediately for internet-facing infrastructure (VPNs, firewalls, file-transfer tools), since exploitation of new CVEs often begins within 24–48 hours of disclosure.
- Deploy intrusion detection/prevention systems (IDS/IPS) and behaviour-based monitoring, since signature-based tools cannot catch unknown exploits.
- Use network segmentation and multi-factor authentication so that a single compromised edge device does not grant unrestricted access to the internal network.

3. Conclusion & Future Scope

The 2024–2025 threat landscape shows a clear pattern: attackers are professionalizing (ransomware-as-a-service), industrializing (AI-generated phishing and deepfakes at scale), and expanding their target surface (billions of new IoT devices and cloud workloads). No single control eliminates these risks; effective defense requires layering technical measures (MFA, Zero Trust, patch management, CSPM tooling) with organizational preparedness (incident response plans, tested backups) and continuous human awareness training, since many of the largest breaches above began with a misconfiguration, a stolen credential, or a convincingly faked human voice rather than a purely technical failure. Because new attack techniques and vulnerabilities emerge constantly — and because AI is now accelerating both the attacker's and defender's side of this equation — cybersecurity cannot be treated as a one-time project. Continuous learning, threat intelligence monitoring, and regular security assessments (penetration testing, vulnerability scanning) are essential for individuals and organizations to keep pace with an adversary that adapts faster than static defenses can.

4. References

1. Jericho Security — "Deepfake Phishing: The AI-Powered Social Engineering Threat Putting CISOs on High Alert in 2025."
<https://www.jerichosecurity.com/blog/deepfake-phishing-the-ai-powered-social-engineering-threat-putting-cisos-on-high-alert-in-2025>
2. PurpleSec — "The Average Cost of Ransomware Attacks (Updated 2025)."
<https://purplesec.us/learn/average-cost-of-ransomware-attacks/>
3. Cloud Security Alliance — "Case Study: Inadequate Configuration & Change Control (Football Australia 2024)."
<https://cloudsecurityalliance.org/blog/2025/06/09/the-2024-football-australia-data-breach-a-case-of-misconfiguration-and-inadequate-change-control>
4. NHI Mgmt Group — "Major AWS S3 Bucket Breach Exposes Data in Cybersecurity Attack (Codefinger, 2025)."
<https://nhimg.org/community/nhi-breaches/major-aws-s3-bucket-breach-exposes-data-in-cybersecurity-attack/>
5. Krebs on Security — "Feds Disrupt IoT Botnets Behind Huge DDoS Attacks."
<https://krebsonsecurity.com/2026/03/feds-disrupt-iot-botnets-behind-huge-ddos-attacks/>
6. Vectra AI — "IoT Security in 2026: threats, risks, and best practices."
<https://www.vectra.ai/topics/iot-security>
7. Google Cloud Blog (Mandiant) — "Ivanti Connect Secure VPN Targeted in New Zero-Day Exploitation."
<https://cloud.google.com/blog/topics/threat-intelligence/ivanti-connect-secure-vpn-zero-day>
8. CSO Online — "Top 7 zero-day exploitation trends of 2024."
<https://www.csoonline.com/article/3629815/top-7-zero-day-exploitation-trends-of-2024.html>
9. CISA — "Understanding Ransomware Threat Actors: LockBit."
<https://www.cisa.gov/news-events/cybersecurity-advisories/aa23-165a>